

Guía metodológica de la Encuesta OCTAVE Nacional

Cómo utilizar la encuesta para medir madurez, riesgo y retorno de la inversión en ciberseguridad con un mínimo de rigor y un máximo de utilidad.

1. Objetivos de la encuesta

La encuesta OCTAVE Nacional tiene tres objetivos principales:

1. Caracterizar la madurez de ciberseguridad de organizaciones españolas (especialmente operadores esenciales e importantes) siguiendo la lógica OCTAVE (activos, amenazas, vulnerabilidades, riesgos, controles, resultados).
2. Cuantificar un Índice Global de Madurez (IGM) que permita comparar unidades organizativas, sectores y evolución temporal.
3. Proporcionar insumos para estimar el ROI (y ROSI) de la ciberseguridad, conectando inversiones, reducción de riesgo y métricas operativas (MTTD, MTTR, incidentes evitados, etc.).[web:59][web:65][web:67]

La encuesta no pretende sustituir a auditorías técnicas ni a análisis MAGERIT/ISO 27005; pretende, más bien, ofrecer una vista panorámica —honesta y comparable— que permita orientar prioridades y decisiones de inversión.

2. Población objetivo y muestreo

2.1. Población objetivo

La encuesta está diseñada para ser respondida por **personas con visión transversal** de la gestión de la ciberseguridad en la organización:

- CISO / Responsable de Seguridad de la Información.
- Responsables de riesgos, cumplimiento o continuidad de negocio.
- Miembros de la alta dirección con responsabilidad sobre ciberseguridad.

En organizaciones grandes, puede ser útil aplicar la encuesta por **unidad de negocio, país o línea de servicio**, siempre que exista alguien con visión global en cada ámbito.

2.2. Estrategia de muestreo

Se recomiendan dos niveles:

- Nivel macro (inter-organizacional): selección de una muestra estratificada de organizaciones por tipo (operador esencial, administración, PYME, etc.), sector y tamaño.
- Nivel micro (intra-organizacional): aplicación de la encuesta a varias áreas clave (por ejemplo, negocio core, TI corporativo, filiales críticas), para capturar heterogeneidad interna.

El objetivo no es la representatividad estadística perfecta, sino un equilibrio razonable entre **cobertura sectorial** y **profundidad de diagnóstico**.

3. Estructura de la encuesta y dominios de madurez

La encuesta se organiza en los siguientes bloques, que se interpretan como **dominios de madurez** para el cálculo del IGM:

4. Gobernanza, estrategia y apetito de riesgo (Bloque B).
5. Identificación y gestión de activos (Bloque C).
6. Criterios de impacto, medición del riesgo y uso de OCTAVE (Bloque D).
7. Vulnerabilidades, amenazas y superficie de ataque (Bloque E).
8. Incidentes, continuidad y resiliencia (Bloque F).
9. Capacidades, cultura y formación (Bloque G).
10. Alineamiento normativo y marcos de referencia (Bloque H).
11. Métricas, IGM y ROI (Bloque I).
12. Percepción global y prioridades (Bloque J).

Cada dominio corresponde a componentes clave de OCTAVE Allegro/FORTE y de marcos como ENS, NIS2, NIST CSF e ISO 27001/27005 (gestión de activos, análisis de riesgos, respuesta a incidentes, mejora continua).[web:4][web:5][web:66][web:60]

4. Escalas de respuesta y codificación

4.1. Escalas Likert 1-5 de madurez

La mayoría de preguntas se codificarán en una escala de 1 a 5:

- 1 = Inexistente / puramente reactivo.
- 2 = Inicial / ad-hoc.
- 3 = Definido pero irregular.
- 4 = Gestionado y medido.
- 5 = Optimizado / integrado en negocio.

Esta escala es compatible con modelos de madurez ampliamente usados (por ejemplo, NIST CSF Tiers, modelos basados en CMMI), facilitando el diálogo con otros marcos.[web:61][web:58][web:64]

4.2. Preguntas con opciones categóricas

Algunas preguntas usan opciones nominales (por ejemplo, tipo de organización, tamaño). Dichas variables se utilizarán como **variables de segmentación**, no como parte directa del IGM.

4.3. Preguntas multi-respuesta

Las preguntas que permiten marcar varias opciones (por ejemplo, barreras, prioridades) se codificarán como variables binarias (0/1 por opción), útiles para análisis exploratorios pero no necesariamente incluidas en el cálculo del IGM.

5. Cálculo del Índice Global de Madurez (IGM)

5.1. Paso 1 – Asignación de puntuaciones por pregunta

Para cada pregunta de madurez (principalmente Bloques B a I):

- Asignar valores numéricos de 1 a 5 según la opción elegida.
- En preguntas con opciones de texto libre o “No aplica”, codificar como:
- NA (no aplica) → excluir de los cálculos de ese dominio.
- Sin respuesta → marcar como dato faltante.

5.2. Paso 2 – Cálculo de puntuaciones por dominio

Para cada dominio (d):

$$(\text{Puntuación media de dominio})_d = \frac{\sum_{i \in d} x_i}{N_d}$$

donde (x_i) es la puntuación de la pregunta i y (N_d) el número de preguntas válidas en el dominio.

La puntuación resultante estará entre 1 y 5.

5.3. Paso 3 – Normalización a escala 0-100

Para facilitar la comunicación al consejo y comparaciones entre dominios, se recomienda transformar las puntuaciones 1-5 en una escala 0-100:

$$(\text{Puntuación normalizada})_d = \frac{(\text{Puntuación media})_d - 1}{4} \times 100$$

Así:

- 1 → 0.
- 3 → 50.
- 5 → 100.

5.4. Paso 4 – Cálculo del IGM global

El Índice Global de Madurez de la organización se obtiene como media ponderada de los dominios:

$$(\text{IGM}) = \sum_d w_d \times (\text{Puntuación normalizada})_d$$

Si no se desea priorizar ningún dominio, se pueden usar **pesos iguales**:

- ($w_d = 1/D$), donde (D) es el número de dominios.

Como alternativa, es posible asignar **mayor peso** a dominios considerados más críticos (por ejemplo, Gobernanza, Incidentes y Alineamiento normativo) en sectores regulados.[web:19][web:21][web:63][web:71]

5.5. Interpretación del IGM

Se propone la siguiente lectura cualitativa:

- 0–20: Muy bajo – Riesgo elevado, programa principalmente reactivo.
- 21–40: Bajo – Bases incipientes, huecos significativos.
- 41–60: Medio – Programa razonable, pero con brechas destacables.
- 61–80: Alto – Programa robusto, en mejora continua.
- 81–100: Muy alto – Referencia sectorial, enfoque proactivo e integrado.

6. Estimación del ROI (y ROSI) de la ciberseguridad

6.1. Conceptos básicos

El ROI clásico se define como:

$$(ROI = \frac{\text{Beneficios} - \text{Costes}}{\text{Costes}})$$

Aplicado a ciberseguridad, el reto es **cuantificar los beneficios**, que suelen consistir en pérdidas evitadas, reducción de probabilidad o impacto de incidentes, mejora de eficiencia, y habilitación de negocio.[web:59][web:65][web:70]

La industria utiliza a menudo el concepto de **Return on Security Investment (ROSI)** o de **Return on Mitigation (RoM)**, donde los beneficios se expresan como reducción del riesgo económico (pérdidas esperadas) o de otros impactos medidos.[web:62][web:67][web:70]

6.2. Datos necesarios

A partir de la encuesta, se recomiendan los siguientes datos (que pueden complementar a la misma en un formulario adicional):

- Costes de ciberseguridad:
- Inversión anual en tecnología de seguridad.
- Costes de personal dedicado.
- Costes de servicios externos (consultoría, auditoría, SOC, etc.).
- Datos de incidentes:
- Número de incidentes significativos por año.
- Coste medio por incidente (directo e indirecto) estimado.
- Duración media de interrupciones (horas) y coste por hora de parada.
- Reducción de incidentes o impacto tras medidas clave:
- Comparación antes/después de iniciativas relevantes.

6.3. Ejemplo de fórmula de ROSI simplificada

13. Estimar la pérdida anual esperada antes de la inversión:

$$(AE_{\text{antes}} = \text{Probabilidad}_{\text{antes}} \times \text{Impacto}_{\text{medio}})$$

14. Estimar la pérdida anual esperada después de la inversión:

$$(AE_{\text{después}} = \text{Probabilidad}_{\text{después}} \times \text{Impacto}_{\text{medio}})$$

15. Calcular la reducción de riesgo monetizada:

$$(\text{Reducción de riesgo} = AE_{\{\text{antes}\}} - AE_{\{\text{después}\}})$$

16. Calcular el ROSI:

$$(\text{ROSI} = \frac{\text{Reducción de riesgo} - \text{Coste de la inversión}}{\text{Coste de la inversión}})$$

Este esquema encaja con las recomendaciones recientes que insisten en medir ROI como **valor de reducción de riesgo** más que como simple ahorro contable.[web:59][web:65][web:67][web:70]

6.4. Uso del IGM en el análisis de ROI

El IGM puede utilizarse como indicador de contexto para el ROI:

- Organizaciones con IGM bajo pueden mostrar altas pérdidas esperadas, de modo que pequeñas inversiones con gran impacto en madurez generen ROSI elevado.
- En organizaciones con IGM alto, el foco puede estar en mantener el nivel y demostrar que la inversión preserva la resiliencia frente a amenazas crecientes.

7. Tratamiento de datos, anonimización y ética

- Se recomienda anonimizar las respuestas de organizaciones individuales en los análisis agregados, salvo consentimiento explícito.
- Los datos se deben usar exclusivamente para mejora de la ciberseguridad y no para mecanismos punitivos internos.
- La publicación de resultados agregados por sector puede ser una palanca poderosa para la mejora colectiva, siempre cuidando la confidencialidad.

8. Visualización y comunicación de resultados

8.1. Cuadros de mando y gráficos sugeridos

- Radar de madurez por dominios (B-I).
- Barras comparativas de IGM por unidad de negocio o país.
- Trayectorias temporales (IGM por año).
- Matrices que crucen IGM con indicadores de incidentes (frecuencia, impacto).

8.2. Mensaje para la alta dirección

- Evitar sobrecargar con indicadores técnicos.
- Destacar 3-5 mensajes clave: dominios fuertes, dominios débiles, tendencia, riesgos prioritarios y estimación de ROI/ROSI.
- Presentar un plan de acción con medidas priorizadas y beneficios esperados.

9. Limitaciones y mejoras futuras

- El IGM es un indicador compuesto, no un oráculo: depende de la calidad y honestidad de las respuestas.
- El cálculo de ROI/ROSI se apoya en estimaciones; conviene revisar hipótesis al menos anualmente.
- La encuesta puede evolucionar para incorporar nuevos requisitos normativos (actualizaciones de ENS, desarrollo de NIS2, guías de ENISA y de la OCDE sobre medición de ciberseguridad).[web:19][web:21][web:51][web:63][web:71]

En resumen, la encuesta OCTAVE Nacional es una brújula, no un GPS infalible. Pero una brújula honesta, bien calibrada y compartida puede marcar la diferencia entre navegar el ciber-temporal con rumbo o limitarse a esperar que la tormenta amaine sola.